

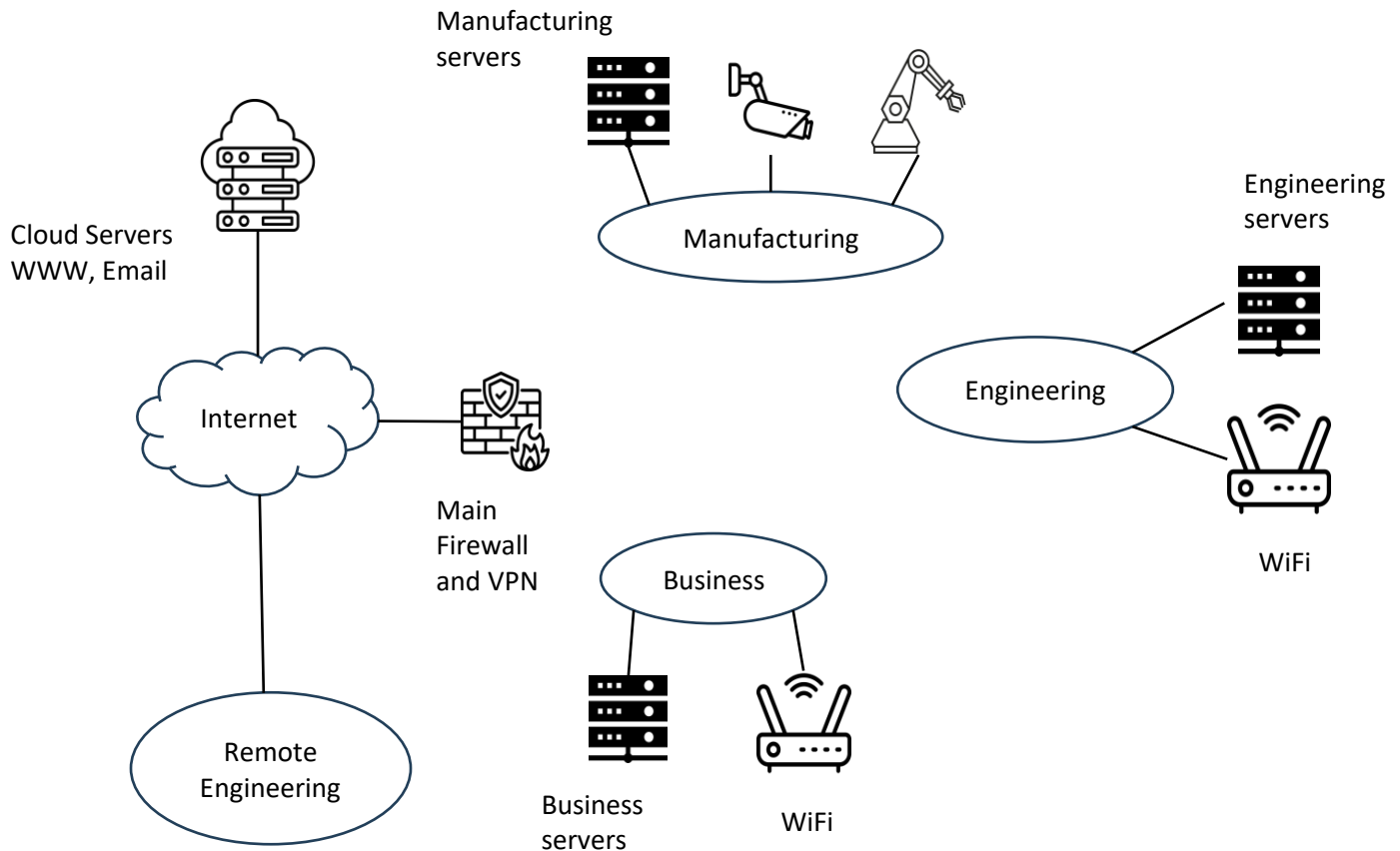
NAME: Gurumanie Singh Dhiman**SCORE:** _____ out of 100

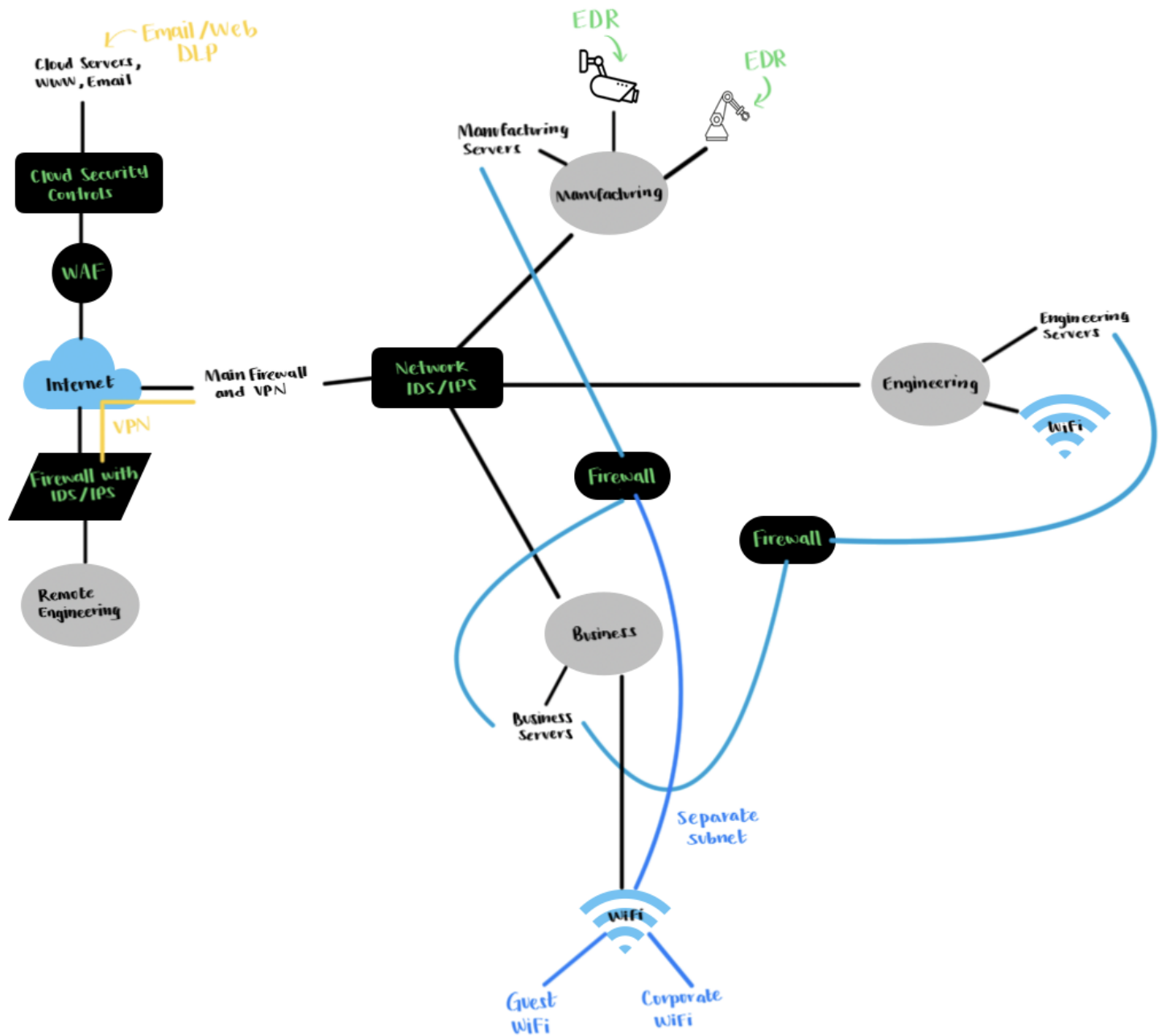
1. (40 pts) Your first task is to develop a plan to improve the security of the network below. The company has three internal networks and a remote engineering site connected to the main network via the Internet. They also use cloud-based services for email and web. Below is the company's high-level network diagram.

Deploy the following devices on the company network to enhance security. Show how you would make the network more secure by providing a drawing of your proposed network architecture on the next page. **Make sure you label the devices.**

Devices available to you (you can use more than one of each type):

- Intrusion detection/prevention system(s)
- Firewall(s)
- Data loss prevention
- Any network device(s)
- Any other device you think would help





2. (56 pts) Based on your new network design, indicate which device/system would mitigate the attacks listed below. If no device is in place, indicate how you would mitigate it; this can include adding host-based mitigation.

a. Malware is sent via an email attachment.

Cloud email security controls would catch this and if not we can also have EDR on the hosts for mitigating malware.

b. Brute force password guessing attack against the cloud web server.

The Web Application Firewall labelled WAF in my diagram would be effective for such an attack. Also I think rate-limiting could be added to the Cloud Web Server to further take action against such an attack.

c. User VPN credentials found on the dark web.

We could enforce MFA for the VPN connection, possibly even try to revoke the credentials and use IDS/IPS to watch for any anomalies.

d. An adversary made an email request for engineering drawings.

Such an attack could be mitigated using phishing filters and DLP to prevent sensitive engineering drawings to be sent out. On top of this since it is a form of social engineering attack, we could implement user awareness trainings so that they are aware of such attacks.

e. Ransomware that bypasses the network-based mitigation and is installed on a trusted computer on the business network.

Endpoint EDR would prove to be effective in such a case. Furthermore, in this EDR we could try to set it to behavior based blocking for further improvement. There are also mitigations such as network segmentation and taking backups on a regular basis.

f. An email claiming to be from a supplier requesting a change in the bank routing numbers.

Email security needs to be implemented to mitigate such an attack. This could include things such as anti-phishing features and also enabling strong financial process controls (by having dual approval).

g. Someone leaves a USB thumb drive in the lobby with malware that an employee picks up.

We can disable or possibly even restrict USB thumb drive by having a policy in place. Another way to mitigate such an attack is to use some form of Endpoint EDR that is able to detect insertion of USB into a company endpoint device and scan it immediately.

3. (4 pts) Comment on the class:

I really enjoyed learning about how to be able to think like an attacker. Overall, I would definitely take this class again. A minor suggestion might be to have a little bit more information on exactly how the break-in lab should be approached from a more adversarial standpoint.